Лабораторная работа: Аудит действий пользователей в Microsoft SQL Server с помощью SQL Server Audit

Цель работы

Изучить механизм SQL Server Audit и научиться:

- создавать аудит сервера;
- создавать аудит базы данных;
- отслеживать действия пользователей;
- фиксировать события входа;
- отслеживать SELECT, INSERT, UPDATE, DELETE;
- анализировать результаты аудита;
- выявлять подозрительную активность.

Теоретическая часть

Что такое SQL Server Audit

SQL Server Audit — это встроенный механизм Microsoft SQL Server, который позволяет фиксировать действия пользователей и администраторов.

С помощью аудита можно отслеживать:

- кто вошел в систему;
- кто выполнил SELECT;
- кто изменил или удалил данные;
- кто создавал или удалял объекты;
- кто изменял права доступа;
- кто пытался выполнить запрещенные действия.

Аудит особенно важен для:

- расследования инцидентов;
- контроля сотрудников;
- выполнения требований PCI DSS, ISO 27001 и других стандартов;
- выявления несанкционированных изменений.

Структура SQL Server Audit

SQL Server Audit состоит из двух частей:

1. SQL Server Audit — определяет, куда записывать события.
2. Audit Specification — определяет, какие именно события записывать.

События можно сохранять:

- в файл;
- в журнал приложений Windows;
- в журнал безопасности Windows.

В лабораторной работе будет использоваться запись в файл.

Подготовка среды

Создайте тестовую базу данных:

```
CREATE DATABASE AuditLab;
GO

USE AuditLab;
GO
```

Создайте таблицу:

```
CREATE TABLE Employees
(
    EmployeeID INT PRIMARY KEY,
    FullName NVARCHAR(100),
    Department NVARCHAR(100),
    Salary INT
);
```

Добавьте тестовые данные:

```
INSERT INTO Employees
VALUES
(1, 'Иванов Иван', 'IT', 800000),
(2, 'Петров Петр', 'Finance', 900000),
(3, 'Сидоров Алексей', 'HR', 650000);
```

Часть 1. Создание SQL Server Audit

Создайте папку для хранения файлов аудита, например:

```
C:\SQLAudit\
```

Создайте аудит:

```
USE master;
GO

CREATE SERVER AUDIT Audit_UserActions
TO FILE
(
    FILEPATH = 'C:\SQLAudit\',
    MAXSIZE = 100 MB,
    MAX_ROLLOVER_FILES = 10,
    RESERVE_DISK_SPACE = OFF
);
GO
```

Включите аудит:

```
ALTER SERVER AUDIT Audit_UserActions
WITH (STATE = ON);
GO
```

Часть 2. Создание Server Audit Specification

Создайте спецификацию для отслеживания входов и ошибок входа:

```
CREATE SERVER AUDIT SPECIFICATION Audit_LoginEvents
FOR SERVER AUDIT Audit_UserActions
ADD (SUCCESSFUL_LOGIN_GROUP),
ADD (FAILED_LOGIN_GROUP),
ADD (LOGOUT_GROUP)
WITH (STATE = ON);
GO
```

Теперь SQL Server будет фиксировать:

- успешные входы;
- неудачные входы;
- выходы пользователей.

Часть 3. Создание Database Audit Specification

Перейдите в базу AuditLab:

```
USE AuditLab;
GO
```

Создайте спецификацию:

```
CREATE DATABASE AUDIT SPECIFICATION Audit_EmployeeActions
FOR SERVER AUDIT Audit_UserActions
ADD (SELECT ON dbo.Employees BY PUBLIC),
ADD (INSERT ON dbo.Employees BY PUBLIC),
ADD (UPDATE ON dbo.Employees BY PUBLIC),
ADD (DELETE ON dbo.Employees BY PUBLIC)
WITH (STATE = ON);
GO
```

Теперь аудит будет фиксировать:

- чтение данных;
- добавление записей;
- изменение записей;
- удаление записей.

Часть 4. Генерация событий

Выполните несколько действий:

```
SELECT * FROM Employees;

INSERT INTO Employees
VALUES
(4, 'Касымов Ержан', 'IT', 750000);

UPDATE Employees
SET Salary = 850000
WHERE EmployeeID = 1;

DELETE FROM Employees
WHERE EmployeeID = 3;
```

Часть 5. Просмотр результатов аудита

Для просмотра используйте функцию:

```sql
SELECT *
FROM sys.fn_get_audit_file
(
    'C:\SQLAudit\*',
    DEFAULT,
    DEFAULT
);
```

Полезные поля:

- event_time;
- action_id;
- succeeded;
- session_server_principal_name;
- database_name;
- object_name;
- statement;
- server_principal_name;
- client_ip.

Часть 6. Поиск подозрительных действий

Поиск удалений

```sql
SELECT event_time,
       server_principal_name,
       object_name,
       statement
FROM sys.fn_get_audit_file
(
    'C:\SQLAudit\*',
    DEFAULT,
    DEFAULT
)
WHERE action_id = 'DL';
```

Поиск изменений зарплаты

```sql
SELECT event_time,
       server_principal_name,
       statement
FROM sys.fn_get_audit_file
(
    'C:\SQLAudit\*',
    DEFAULT,
```

```
    DEFAULT
)
WHERE statement LIKE '%Salary%';
```

Поиск неудачных входов

```
SELECT event_time,
       server_principal_name,
       succeeded,
       statement
FROM sys.fn_get_audit_file
(
    'C:\SQLAudit\*',
    DEFAULT,
    DEFAULT
)
WHERE action_id = 'LGIF';
```

Поиск действий конкретного пользователя

```
SELECT event_time,
       action_id,
       object_name,
       statement
FROM sys.fn_get_audit_file
(
    'C:\SQLAudit\*',
    DEFAULT,
    DEFAULT
)
WHERE server_principal_name = 'TestUser';
```

Часть 7. Аудит изменения прав доступа

Создайте дополнительную спецификацию:

```
USE master;
GO

CREATE SERVER AUDIT SPECIFICATION Audit_PermissionChanges
FOR SERVER AUDIT Audit_UserActions
ADD (SERVER_ROLE_MEMBER_CHANGE_GROUP),
ADD (DATABASE_ROLE_MEMBER_CHANGE_GROUP),
ADD (DATABASE_PERMISSION_CHANGE_GROUP)
```

```
WITH (STATE = ON);
GO
```

Теперь будут фиксироваться:

- выдача прав;
- отзыв прав;
- добавление пользователей в роли.

Часть 8. Аудит создания и удаления объектов

```
USE AuditLab;
GO

CREATE DATABASE AUDIT SPECIFICATION Audit_ObjectChanges
FOR SERVER AUDIT Audit_UserActions
ADD (SCHEMA_OBJECT_CHANGE_GROUP)
WITH (STATE = ON);
GO
```

Проверьте:

```
CREATE TABLE TestTable
(
    ID INT
);

DROP TABLE TestTable;
```

Часть 9. Отключение аудита

Отключение спецификаций:

```
ALTER DATABASE AUDIT SPECIFICATION Audit_EmployeeActions
WITH (STATE = OFF);

ALTER SERVER AUDIT SPECIFICATION Audit_LoginEvents
WITH (STATE = OFF);
```

Отключение самого аудита:

```
ALTER SERVER AUDIT Audit_UserActions
WITH (STATE = OFF);
```

Дополнительные задания

1. Настроить аудит только для одной выбранной таблицы из своей базы данных.
2. Настроить аудит только для конкретного пользователя или роли.
3. Настроить аудит только операций DELETE и UPDATE.
4. Найти все события за последние 24 часа.
5. Найти все действия пользователя, связанные с изменением важного поля или чувствительных данных.
6. Найти все случаи неудачного входа.
7. Настроить отдельный аудит для пользователей с административными правами.
8. Настроить аудит изменений ролей и прав доступа.
9. Сравнить аудит SQL Server и триггеры аудита.
10. Определить, какие события наиболее критичны для выбранной базы данных или компании.

Контрольные вопросы

1. Что такое SQL Server Audit?
2. Чем отличается Audit от Audit Specification?
3. Какие события можно фиксировать?
4. Где могут храниться результаты аудита?
5. Что делает SUCCESSFUL_LOGIN_GROUP?
6. Что делает FAILED_LOGIN_GROUP?
7. Для чего используется sys.fn_get_audit_file?
8. Какие поля наиболее полезны при расследовании инцидентов?
9. Как найти действия конкретного пользователя?
10. Чем SQL Server Audit лучше обычных триггеров?

Вывод

В ходе лабораторной работы был изучен механизм SQL Server Audit. Были рассмотрены способы аудита входов пользователей, чтения, изменения и удаления данных, а также изменения прав доступа и объектов базы данных. SQL Server Audit позволяет централизованно отслеживать действия пользователей и использовать результаты для расследования инцидентов и повышения безопасности базы данных.